เอกสารการประเมินความเสี่ยงความมั่นคงปลอดภัย (Risk Register)

โครงการพัฒนาระบบ LearnLink (Social Learning Community Platform)

รหัสเอกสาร: SEC-RR-2026-01
สัดส่วนคะแนน: 10%
สถานะ: ฉบับสมบูรณ์ (พร้อมใช้งาน)
กลุ่มเป้าหมาย: ทีมพัฒนาระบบ และ Security Analyst

1. บทนำและบริบทของระบบ (System Context & Scope)

LearnLink เป็นเว็บแอปพลิเคชันประเภท *Social Learning Community* ที่เน้นการแลกเปลี่ยนความรู้และการเรียนรู้ร่วมกัน (Community-based Learning) ผ่านฟีเจอร์หลัก ได้แก่ การโพสต์ข้อความ รูปภาพ วิดีโอ และเอกสารการเรียน, การสร้างและเข้าร่วมกลุ่ม Community ตามรายวิชาหรือหัวข้อสนใจ, การแสดงความคิดเห็น (Comment), การกดถูกใจ (Like) และการติดตามสมาชิก (Follow)

> **วัตถุประสงค์ของเอกสาร:** เอกสาร Risk Register ฉบับนี้จัดทำขึ้นเพื่อระบุ วิเคราะห์ และประเมินความเสี่ยงด้านความมั่นคงปลอดภัยสารสนเทศของระบบ LearnLink พร้อมทั้งเสนอแนวทางการบรรเทาความเสี่ยง (Mitigation Strategies) เพื่อให้สมาชิกในทีมสามารถนำข้อมูลไปต่อยอดในการเขียน Security Requirements, การสร้าง Misuse Case และการออกแบบ System Architecture / DFD ได้อย่างถูกต้องแม่นยำ

2. เกณฑ์การประเมินและระดับความเสี่ยง (Risk Assessment Matrix)

การประเมินความเสี่ยงคำนวณจากสูตร: **ระดับความเสี่ยง (Risk Level) = โอกาสเกิด (Likelihood) × ผลกระทบ (Impact)**

ระดับ	โอกาสเกิด (Likelihood)	ผลกระทบ (Impact)
3 (High)	พบช่องโหว่ง่าย ทำได้โดยไม่ใช้เครื่องมือซับซ้อน	ข้อมูลรั่วไหลเป็นวงกว้าง หรือระบบหยุดทำงาน
2 (Medium)	ต้องใช้ความพยายามหรือสิทธิ์เฉพาะบางส่วน	กระทบผู้ใช้บางกลุ่มหรือข้อมูลไม่สำคัญรั่วไหล
1 (Low)	เงื่อนไขการซ้ำซ้อนเกิดขึ้นได้ยากมาก	กระทบการทำงานเล็กน้อย ไม่เสียความลับข้อมูล

คะแนน (L × I)	ระดับความเสี่ยง (Risk Level)	การรับมือและการแก้ไข
9	**Critical**	ต้องแก้ไขทันทีก่อนเปิดใช้งานระบบ
6	**High**	ต้องมีมาตรการป้องกันและแก้ไขใน Sprint แรก
3 - 4	**Medium**	กำหนดแผนแก้ไขและเฝ้าระวังอย่างต่อเนื่อง
1 - 2	**Low**	ยอมรับความเสี่ยงได้ ควบคุมตามมาตรฐานทั่วไป

3. ทะเบียนความเสี่ยงของระบบ LearnLink (Risk Register Table)

Risk ID	เหตุการณ์ความเสี่ยง (Risk Scenario)	สินทรัพย์ที่ได้รับผลกระทบ (Affected Asset)	L	I	ระดับ	แนวทางการป้องกันและบรรเทาความเสี่ยง (Mitigation Strategy)	ผู้รับผิดชอบ
R-01	**Malicious File Upload:** ผู้ไม่หวังดีอัปโหลดไฟล์ Malware หรือ Web Shell แฝงมากับไฟล์เอกสาร (PDF, Docx) หรือรูปภาพในโพสต์ เพื่อยึด Server หรือแพร่ไวรัสใส่ผู้เรียน	File Upload API, Object Storage (S3/Cloud)	2	3	**High (6)**	• ตรวจสอบ File Extension และ Magic Bytes (MIME-type Check) • สแกนไฟล์ด้วย ClamAV / Virus Scanner ก่อนจัดเก็บ • เปลี่ยนชื่อไฟล์เป็น Random UUID และเก็บแยกบน Cloud Storage ที่ปิดการรัน Script	Backend Dev / DevOps

Risk ID	เหตุการณ์ความเสี่ยง (Risk Scenario)	สินทรัพย์ที่ได้รับผลกระทบ (Affected Asset)	L	I	ระดับ	แนวทางการป้องกันและบรรเทาความเสี่ยง (Mitigation Strategy)	ผู้รับผิดชอบ
R-02	**Stored Cross-Site Scripting (XSS):** ฝัง JavaScript อันตรายไว้ในเนื้อหาโพสต์, คอมเมนต์ หรือชื่อ Community เพื่อขโมย Session Token ของผู้ใช้คนอื่นที่เข้ามาอ่าน Feed	Post & Comment Feed System, User Session	3	3	Critical (9)	• ทำ Input Sanitization ด้วย DOMPurify / Bleach ก่อนบันทึก • ใช้ HTML Entity Encoding เมื่อแสดงผลบน Frontend • กำหนด Content Security Policy (CSP) ห้ามรัน Inline Script	Frontend / Backend Dev
R-03	**IDOR in Private Community:** ผู้ใช้ทั่วไปแอบแก้ไข ID บน API Request เพื่อเข้าถึงโพสต์ เอกสาร หรือลบเนื้อหาใน Private Community ที่ตนเองไม่ได้เป็นสมาชิก	Community API, Document Store	3	3	Critical (9)	• บังคับตรวจ Authorization Check ที่ Backend ทุกครั้งที่มีการเรียกข้อมูล • เปลี่ยนการอ้างอิง Resource จาก Auto-increment ID เป็น UUID (v4)	Backend Dev
R-04	**Unauthorized Material Access:** การเข้าถึงไฟล์ชีทเรียน/เอกสารในกลุ่มปิดโดยตรงผ่าน Direct URL โดยไม่ผ่านการตรวจสอบสิทธิ์ล็อกอิน	Cloud Storage Buckets, Asset CDN	2	2	Medium (4)	• กำหนดสิทธิ์ Cloud Storage เป็น Private ทั้งหมด • ส่งมอบไฟล์ผ่าน Pre-signed URL / Signed Cookies ที่กำหนดเวลาหมดอายุ (เช่น 15 นาที)	DevOps / Cloud Admin
R-05	**Account Takeover & Brute Force:** ถูกเดารหัสผ่าน หรือสุ่มล็อกอินเพื่อยึดบัญชีผู้เรียน/ผู้สอน แล้วนำไปโพสต์ข้อความหลอกลวง (Phishing)	Auth Service, User Account DB	2	3	High (6)	• เข้ารหัส Password ด้วย Argon2id หรือ BCrypt (Work Factor ≥ 12) • ตั้งค่า Rate Limiting ที่หน้า Login (ไม่เกิน 5 ครั้ง/นาที) • ใช้ HttpOnly, Secure, SameSite Cookie สำหรับเก็บ JWT/Session	Backend Dev / Security
R-06	**API Abuse & Data Scraping:** บอทแอบดึงข้อมูลเนื้อหาการเรียน โปรไฟล์ผู้เรียน หรือยิง Request จำนวนมากจนทำให้ระบบช้าหรือล่ม (DoS)	Public Feed API, Search API	3	2	High (6)	• ติดตั้ง API Gateway และกำหนด Rate Limiting ตาม IP / User Account • ใช้งาน Cloudflare WAF ตรวจจับ Bot Traffic • บังคับให้ต้องมี API Key / Auth Token ในการดึงข้อมูลส่วนใหญ่	DevOps / Infra
R-07	**Spam & Inappropriate Content:** บอทหรือผู้ใช้สร้างโพสต์สแปม โฆษณาเว็บพนัน หรือเนื้อหาไม่เหมาะสมใน Community ทำลายบรรยากาศการเรียนรู้	Community Feeds, Notification System	3	2	High (6)	• ระบบกรองคำต้องห้าม (Forbidden Keywords Filter) • เพิ่มปุ่ม "Report Post/User" และระบบแจ้งเตือนไปยัง Admin/Moderator • ระบบ Auto-hide โพสต์ชั่วคราวเมื่อถูก Report เกิน 5 ครั้ง	Backend / Frontend Dev

Risk ID	เหตุการณ์ความเสี่ยง (Risk Scenario)	สินทรัพย์ที่ได้รับผลกระทบ (Affected Asset)	L	I	ระดับ	แนวทางการป้องกันและบรรเทาความเสี่ยง (Mitigation Strategy)	ผู้รับผิดชอบ
R-08	**Privilege Escalation (Admin Role):** ผู้ใช้ทั่วไปแอบส่ง Request แก้ไข Role ของตนเองเป็น Moderator หรือ Admin ของระบบ	User Management API, RBAC Core	1	3	Medium (3)	• ปิดการอัปเดต Field `role` ผ่าน Public Update Profile API • การเปลี่ยน สิทธิ์ Admin/Moderator ต้องทำผ่าน Admin Panel เฉพาะเท่านั้น	Backend Dev
R-09	**SSRF via External Link Preview:** ฟังก์ชันดึงภาพ/หัวข้อเมื่อแปะ Link เว็บภายนอกในโพสต์ ถูกหลอกให้ยิง Request เข้าหา Internal Network Server	Post Link Parsing Service	1	3	Medium (3)	• บล็อกไม่ให้ Fetch URL ที่เป็น Private IP (127.0.0.1, 10.x.x.x, 192.168.x.x) • แยก Service สรุป Link ออกไปอยู่ใน Sandbox Network	Backend Dev / Infra
R-10	**Sensitive Data Exposure via API:** API ส่งข้อมูลเกินจำเป็น (Over-fetching) เช่น อีเมล เบอร์โทร หรือ Hashed Password ติดไปกับ Object ผู้โพสต์	User Profile API, Comment API	2	2	Medium (4)	• ใช้ Data Transfer Object (DTO) กำหนด Field ที่จะแสดงผลอย่างชัดเจน • ตัด Sensitive Fields ออกจาก JSON Response ก่อนส่งกลับ Frontend	Backend Dev

4. คำแนะนำการนำข้อมูลไปส่งต่อให้เพื่อนในทีม (Team Implementation Guide)

1. สำหรับทีม DFD / Threat Modeling (STRIDE)

- นำ **R-01, R-04** ไปใส่ Trust Boundary ระหว่าง Web Server กับ External Storage (S3)
- นำ **R-02, R-03, R-08** ไปวิเคราะห์ในจุด Data Flow จาก Client เข้าหา API Gateway และ Database (STRIDE: Tampering & Elevation of Privilege)

2. สำหรับทีมทำ Misuse Case

- ดึง Scenario ไปสร้าง Misuse Actor เช่น *"Attacker tries to upload Web Shell via Post Document Attachment"* (จาก R-01)
- สร้าง Misuse Scenario *"Unauthorized User accesses Private Course Notes via Direct URL Manipulate"* (จาก R-03, R-04)

3. สำหรับทีมทำ Security Requirements

- แปลง Mitigation Strategy ในตารางเป็นข้อกำหนดระบบ เช่น **SR-01:** *"ระบบต้องทำการ Sanitization ข้อมูล Input ทั้งหมดเพื่อป้องกัน Stored XSS"*
- **SR-02:** *"การเข้าถึงไฟล์เอกสารในกลุ่มปิดต้องกระทำผ่าน Pre-signed URL ที่มีอายุไม่เกิน 15 นาที"*

4. สำหรับทีมออกแบบ Architecture & Cloud

- เพิ่มกล่อง **WAF / Rate Limiter** ไว้หน้า API Gateway (จาก R-05, R-06)
- เพิ่มกล่อง **Virus Scanner Container / S3 Event Trigger** สำหรับสแกนไฟล์อัปโหลดก่อนจัดเก็บลง DB (จาก R-01)

5. แนวทางการติดตามและทบทวนความเสี่ยง (Monitoring & Audit Plan)

1. **วงรอบการทบทวน:** กำหนดให้มีการทบทวน Risk Register ทุกครั้งที่มีการเพิ่ม Module ใหม่ หรืออย่างน้อยทุกๆ 2 สัปดาห์ในช่วงการพัฒนาโปรเจกต์
2. **การทดสอบความปลอดภัย:** ดำเนินการทำ Static Application Security Testing (SAST) และสแกน Dependency ช่องโหว่ด้วย Snyk / GitHub Dependabot ก่อนรวม Code เข้าสู่ Main Branch